Computer security: principles and practice

هو كتاب أكاديمي مشهور في مجال أمن الحاسوب يُستخدم كثيرًا في الجامعات لتدريس أساسيات أمن المعلومات والشبكات.

اهم ما يتناوله الكتاب:

- أساسيات أمن الحاسوب ومفاهيم الحماية.
- التشفير (Cryptography) وخوارزميات التشفير المختلفة.
- أمن الشبكات وبروتوكولات الحماية.
- إدارة كلمات المرور والمصادقة.
- الهجمات السيبرانية وطرق اكتشافها ومنعها.
- أمن الأنظمة والتطبيقات.

المؤلفان

William Stallings. ويليام ستالينغز.

Laurie Brown لوري براون

يُعد هذا الكتاب من المراجع الأساسية لطلاب أمن المعلومات وعلوم الحاسوب لأنه يشرح المفاهيم النظرية مع أمثلة وتطبيقات عملية.

إذا أردت، يمكنني أيضا أن أعطيك ملخصا لأهم فصول الكتاب أو خريطة مبسطة لمحتواه ليسهل مذاكرته.

User authentication

اداة أساسية في بناء الأمان الأمن المعلوماتي).

الأساس للتحكم في الوصول ومساءلة المستخدم.

هي عملية التحقق من هوية يدّعيها كيان في النظام أو تُنسب إليه.

تتكون من خطوتين:

التعريف : (Identification تحديد المعرّف.

. التحقق : (Verification) ربط الكيان (الشخص) بالمعرّف.

. وهي تختلف عن توثيق الرسائل (Message

.(Authentication

Means of User authentication

أربع وسائل للتحقق من هوية المستخدم:

تعتمد على شيء يمتلكه الفرد أو يميّزه، مثل:

- شيء يعرفه المستخدم : مثل كلمة المرور أو الرقم السري.(PIN)
- شيء يملكه المستخدم : مثل المفتاح، أو الرمز المميز (Token) ، أو البطاقة الذكية.
- شيء يكونه المستخدم (قياسات حيوية ثابتة) : مثل بصمة الإصبع أو شبكية العين.
- شيء يفعله المستخدم (قياسات حيوية ديناميكية) : مثل الصوت أو التوقيع.
- يمكن استخدام أي وسيلة بشكل منفرد أو مجتمعة مع وسائل أخرى.
- جميع هذه الوسائل يمكن أن توفر توثيق هوية المستخدم.
- لكن لكل منها مشكلات أو تحديات خاصة بها.

هناك أربع وسائل عامة للتحقق من هوية المستخدم، ويمكن استخدام هذه الوسائل بشكل منفرد أو بالجمع بينها:

١. شيء يعرفه المستخدم:

من الأمثلة على ذلك كلمة المرور، أو الرقم التعريفي الشخصي ((PIN، أو الإجابة عن مجموعة من الأسئلة التي تم إعدادها مسبقًا.

٢. شيء يملكه المستخدم:

من الأمثلة على ذلك بطاقات المفاتيح الإلكترونية، والبطاقات الذكية، والمفاتيح المادية. ويُشار إلى هذا النوع من وسائل التحقق باسم الرمز المميز (.(Token

٣. شيء يكونه المستخدم (القياسات الحيوية الثابتة):

ومن الأمثلة عليها التعرف على الهوية من خلال بصمة الإصبع، أو شبكية العين، أو ملامح الوجه.

٤. شيء يفعله المستخدم (القياسات الحيوية الديناميكية):

ومن الأمثلة عليها التعرف على الهوية من خلال نمط الصوت، أو خصائص الكتابة اليدوية، أو إيقاع الكتابة على لوحة المفاتيح.

يمكن لجميع هذه الطرق، إذا تم تنفيذها واستخدامها بشكل صحيح، أن توفر مصادقة آمنة للمستخدم. ومع ذلك، فإن لكل طريقة بعض المشكلات. فقد يتمكن المهاجم من تخمين كلمة المرور أو سرقتها، كما قد يتمكن من تزوير أو سرقة الرمز المميز) .(Token وقد ينسى المستخدم كلمة المرور أو يفقد الرمز المميز.

بالإضافة إلى ذلك، هناك عبء إداري كبير في إدارة معلومات كلمات المرور والرموز المميزة داخل الأنظمة وتأمين هذه المعلومات. أما فيما يتعلق بوسائل المصادقة البيومترية، فهناك

مجموعة من التحديات مثل التعامل مع القبول الخاطئ (False Positives)والرفض الخاطئ (False Negatives) ، إضافة إلى قضايا تقبل المستخدمين، والتكلفة، وسهولة الاستخدام.

Password authentication

- طريقة شائعة لمصادقة المستخدم.
- يقوم المستخدم بإدخال اسم المستخدم وكلمة المرور.
- يقارن النظام كلمة المرور مع الكلمة المخزنة للحساب.
- إذا تطابقت، يتم التحقق من هوية المستخدم والسماح له بالدخول إلى النظام.
- بعد ذلك يحدد النظام صلاحيات المستخدم.
- تُستخدم هذه الطريقة في التحكم التقديري في الوصول

(discretionary access control).

تُعد كلمات المرور خط الدفاع الأول ضد المتسللين في الأنظمة متعددة المستخدمين. حيث يُطلب من المستخدم إدخال اسم المستخدم (ID) وكلمة المرور، ثم يقارن النظام كلمة المرور مع الكلمة المخزنة في ملف كلمات المرور. إذا تطابقت، يتم التحقق من هوية المستخدم، وبناءً على المعرف (ID) يحدد النظام إمكانية الوصول والصلاحيات والتحكم التقديري في الوصول.

Password vulnerabilities

- هجوم القاموس غير المتصل :(Offline Dictionary Attack) تجربة قائمة كلمات مرور محتملة دون الاتصال بالنظام.
- هجوم على حساب محدد (Specific Account Attack) استهداف حساب مستخدم معين.
- هجوم كلمات المرور الشائعة : (Popular Password Attack) تجربة كلمات المرور الشائعة الاستخدام.
- .تخمين كلمة المرور لمستخدم واحد Password guessing against single user
- اختطاف محطة العمل : (Workstation hijacking) استغلال جهاز مستخدم تركه مفتوحًا.
- . استغلال أخطاء المستخدمين(Exploiting user Mistakes)
- . استغلال استخدام نفس كلمة المرور في عدة أماكن . Exploiting multiple (passwords use
- المراقبة الإلكترونية : (Electronic Monitoring) التجسس على عملية إدخال كلمة المرور.

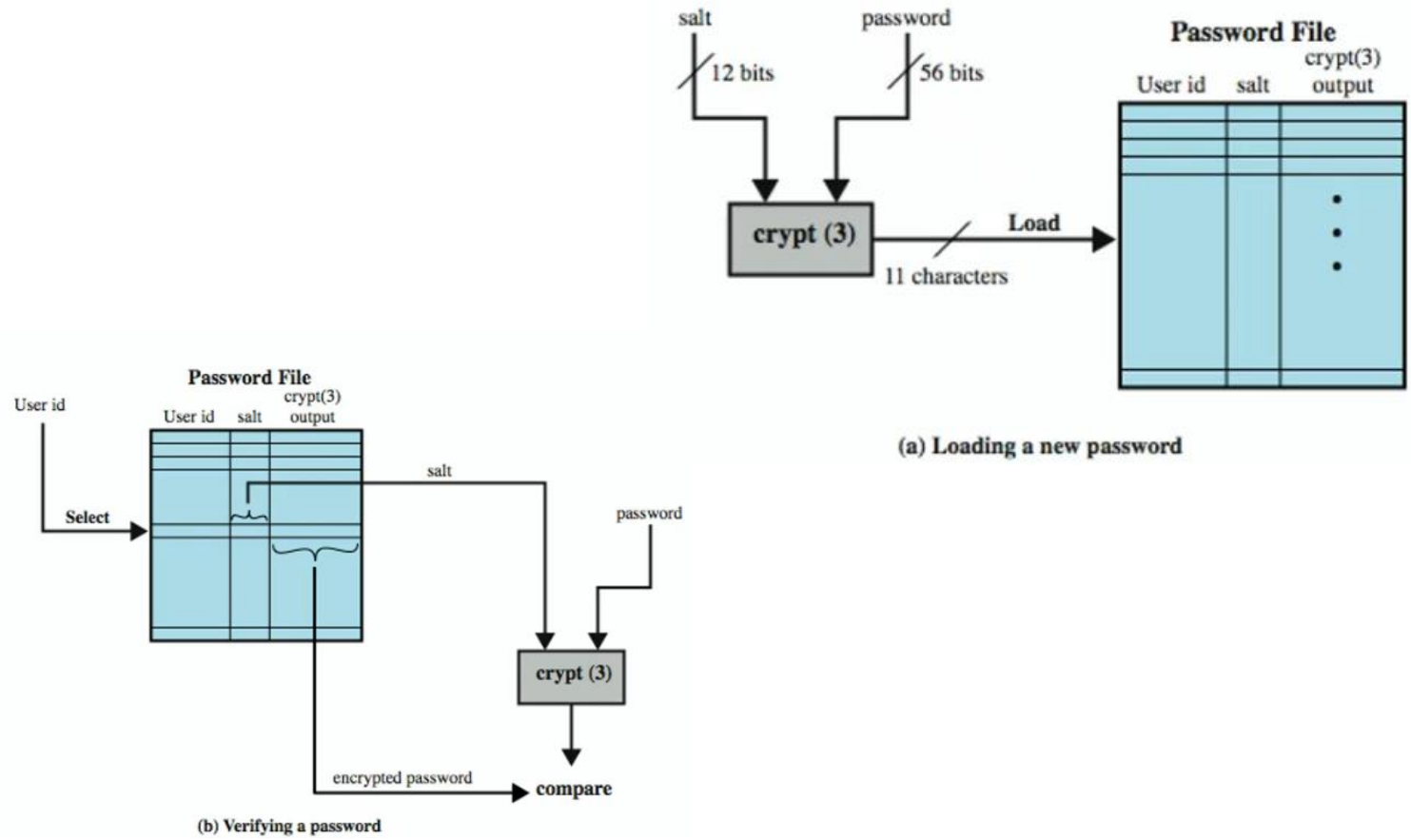
Countermeasures

- منع الوصول غير المصرح به إلى ملف كلمات المرور
- إجراءات كشف التسلل
- آليات قفل الحساب
- سياسات تمنع استخدام كلمات المرور الشائعة وتلزم باستخدام كلمات مرور يصعب تخمينها
- التدريب على السياسات وتطبيقها
- تسجيل الخروج التلقائي من محطة العمل
- تشفير روابط / اتصالات الشبكة

إجراءات الوقاية ضد الثغرات المذكورة تشمل ضوابط تهدف إلى:

- منع الوصول غير المصرح به إلى ملف كلمات المرور
- استخدام وسائل كشف التسلل لتحديد أي اخترا
- إعادة إصدار كلمات المرور بسرعة في حال تم اختراق ملف كلمات المرور
- آلية قفل الحساب بعد عدة محاولات تسجيل دخول فاشلة
- سياسات تمنع اختيار المستخدمين لكلمات مرور شائعة
- التدريب على سياسات كلمات المرور وفرضها لضمان صعوبة تخمينها
- تسجيل الخروج التلقائي لمحطة العمل بعد فترة من عدم النشاط
- منع استخدام نفس كلمة المرور أو كلمات مشابهة على أجهزة الشبكة المختلفة
- تشفير روابط الاتصال والشبكة

Use of Hashed Passwords



استخدام كلمات المرور المشفرة (Hashed Passwords)

مفهومها:

. تعتمد على تحويل كلمة المرور الأصلية إلى قيمة هاش ثابتة الطول باستخدام خوارزمية تشفيرية.

. غالبًا ما تُدمج كلمة المرور مع قيمة Salt لإنتاج هاش فريد لكل مستخدم، حتى لو كانت كلمات المرور متشابهة.

طريقة العمل:

١. عند تعيين كلمة مرور جديدة، تُدمج مع Salt وتُمرّر إلى خوارزمية الهاش.

٢. يُخزن الناتج (الهاش) مع Salt بنص عادي في ملف كلمات المرور.

٣. عند تسجيل الدخول، يُدخل المستخدم كلمة المرور، ويُحسب هاش جديد باستخدام نفس Salt ، ويُقارن بالهاش المخزن.

الأهداف:

- حماية كلمات المرور حتى لو تم الوصول إلى ملف كلمات المرور.
- صعوبة تخمين كلمات المرور بسبب Salt والهاش البطيء التنفيذ.

التهديدات المحتملة:

- تخمين كلمات المرور على الجهاز نفسه عبر برامج التخمين (Password Cracker)
- الحصول على ملف كلمات المرور وتشغيل التخمين على أجهزة أخرى لاستغلال الوقت والموارد.

قيمة Salt هي بيانات عشوائية أو شبه عشوائية تُضاف إلى كلمة المرور قبل تشفيرها (هاش)، والغرض منها:

١. جعل كل هاش فريدًا : حتى لو استخدم مستخدمان نفس كلمة المرور، فإن استخدام Salt مختلف ينتج هاش مختلف لكل مستخدم.

٢. صعوبة الهجمات : يجعل هجمات قاموس الكلمات أو الهجمات بالقوة الغاشمة أصعب، لأن المهاجم لا يستطيع استخدام هاش مسبق الحوسبة دون معرفة.Salt

٣. زيادة التعقيد : في بعض الأنظمة القديمة كان Salt يعتمد على الوقت، أما في الأنظمة الحديثة فيكون قيمة عشوائية أو شبه عشوائية طولها ثابت.

مثال مبسط:

كلمة المرور : password123

Salt عشوائي: X7f!

عند دمجهم وتشغيل الهاش ← ننتج هاش فريد، يختلف عن هاش كلمة

password123بدون. Salt أو مع Salt آخر

تقنية شائعة لحماية كلمات المرور هي استخدام كلمات مرور مشفرة (هاش) مع قيمة Salt. تُستخدم هذه الطريقة في معظم أنظمة UNIX وبعض أنظمة التشغيل الأخرى.

عند تعيين كلمة مرور جديدة للمستخدم، تُدمج مع قيمة Salt ثابتة الطول لتوليد قيمة هاش فريدة، حتى إذا كانت كلمة المرور نفسها، مما يصعّب الهجمات في الإصدارات القديمة، يعتمد Salt على وقت تعيين كلمة المرور، بينما تستخدم الإصدارات الحديثة أرقامًا عشوائية أو شبه عشوائية. يُخزن الهاش الناتج مع نسخة Salt بنص عادي في ملف كلمات المرور.

عند تسجيل الدخول، يستخدم النظام معرّف المستخدم للوصول إلى ملف كلمات المرور واسترجاع Salt وكلمة المرور المشفرة، ويقارن بين الهاش الناتج عن كلمة المرور المدخلة والهاش المخزن لقبول تسجيل الدخول.

تهدّد هذه الطريقة تهديدين رئيسيين:

١. يمكن لمستخدم الوصول عبر حساب ضيف أو وسيلة أخرى وتشغيل برنامج تخمين كلمات المرور على الجهاز.

٢. إذا حصل الخصم على نسخة من ملف كلمات المرور، يمكنه تشغيل برنامج التخمين على جهاز آخر لتجربة ملايين كلمات المرور في وقت معقول.

Unix implementation

المخطط الأصلي لكلمات المرور المشفرة

- كلمة المرور : مكوّنة من ٨ أحرف ← تُحوّل إلى مفتاح - ٥٦ بت.
- ١٢-: Saltبت تُستخدم لتعديل تشفير DES وتحويله إلى دالة هاش أحادية الاتجاه.
- عملية التشفير : قيمة ٠ تشفر ٢٥ مرة متكررة.
- الناتج النهائي : يُحوّل إلى تسلسل مكوّن من ١١ حرفًا.
- الأمان : يُعتبر الآن غير آمن تماما.
- مثال: باستخدام حاسوب فائق، يمكن اختبار ٥٠ مليون كلمة مرور في ٨٠ دقيقة.
- الاستخدام الحالي : أحيانًا يُستخدم فقط لأغراض التوافق مع أنظمة قديمة.

اعتمدت معظم أنظمة UNIX القديمة على مخطط كلمات مرور حيث يختار المستخدم كلمة مرور من ٨ أحرف تُحوّل إلى مفتاح- ٥٦ بت وتُستخدم مع خوارزمية DES مع Salt بطول ١٢ - بت . يتم تشفير كتلة بيانات عدة مرات (٢٥) مرة (ثم تحويل الناتج إلى سلسلة من ١١ حرفًا لتخزينها.

كان الهدف جعل تخمين كلمات المرور أصعب، لكن هذه الطريقة أصبحت ضعيفة أمنيًا لأن الحواسيب الحديثة يمكنها تجربة ملايين كلمات المرور بسرعة. ومع ذلك ما زالت تُستخدم أحيانًا للتوافق مع الأنظمة القديمة.

Improved Implementations

توجد إصدارات أخرى أقوى من نظام الهاش مع Salt المستخدم قديمًا،

مثل:

- تستخدم كثير من الأنظمة الآن MD5 مع Salt بطول ٤٨- بت.
- طول كلمة المرور غير محدود.
- يتم إجراء عملية الهاش ١٠٠٠ مرة لزيادة الأمان.
- ينتج هاش بطول ١٢٨-بت.
- كما يستخدم نظام OpenBSD خوارزمية Bcrypt المعتمدة على تشفير Blowfish، حيث تستخدم Salt بطول ١٢٨ - بت لإنتاج قيمة هاش بطول١٩٢-بت، مما يوفر أمانًا أقوى.

توجد مخططات Hash/Salt أقوى في أنظمة UNIX. تستخدم العديد من الأنظمة مثل Linux و Solaris و FreeBSD خوارزميةMD5 ، التي تستخدم Salt حتى ٤٨-بت ولا تفرض حدًا لطول كلمة المرور، وتنتج هاش بطول ١٢٨ - بت . كما أنها أبطأ من النظام القديم لأنها تستخدم ١٠٠٠ تكرار لزيادة الأمان.

أما OpenBSD فيستخدم مخططًا أكثر أمانًا يسمى Bcrypt يعتمد على خوارزمية Blowfish يسمح بكلمات مرور حتى ٥٥ حرفًا ويستخدم Salt عشوائي بطول ١٢٨-بت لإنتاج هاش بطول ١٩٢ - بت . كما يحتوي على متغير تكلفة (Cost) يمكن زيادته لزيادة وقت الحساب وبالتالي رفع مستوى الأمان، ويمكن للمسؤولين تخصيص تكلفة أعلى للحسابات المهمة .